Báo Cáo Tái Kiểm Định An Ninh & Đánh Giá Mã Nguồn Gate 1 (Gate 1 Security Audit & Code Review) — KZTEK Work Management

- **Mã tài liệu:** `SECURITY-AUDIT-gate1-2026-11-02`
- **Workflow:** `WF-HOTFIX` (Bước 2.1 — Two-Eyes Security Audit & Code Review Gate 1)
- **Tác giả:** Tech Lead (L3 — Lead)
- **Căn cứ kỹ thuật:** `docs/architecture/ADR-001-system-architecture-roadmap.md` & `docs/architecture/ARCH-AUDIT-system-2026-11-02.md`
- **Người thẩm định / Tiếp nhận tiếp theo:** UX/UI Reviewer (Bước 2.2) & QA Engineer (Bước 3.1)
- **Ngày thực hiện:** 2026-11-02
- **Mức độ ưu tiên:** P0 (Chặn Golive — Hotfix An ninh & Ổn định Mạng LAN Pilot)
- **Trạng thái kiểm tra:** 100% `CONFIRMED` từ diff mã nguồn thực tế (`12c4d58..HEAD`), 49/49 automated tests PASS, 0 lỗi TypeScript.

---

1. Tóm Tắt Tổng Quan (Executive Summary)

Sau khi Senior Developer hoàn thành toàn bộ Phase 1 (`STEP-1.1`, `STEP-1.2`, `STEP-1.3`), Tech Lead đã tiến hành quy trình đánh giá mã nguồn 2 trục độc lập (`Standards` & `Spec`) kết hợp kiểm định an ninh chuyên sâu theo khung **OWASP Top 10 (2021)** và mô hình mối đe dọa **STRIDE** trên toàn bộ 63 files thay đổi (3.483 dòng thêm, 901 dòng xóa).

Kết quả then chốt

1. **Xóa sạch toàn bộ 5/5 lỗ hổng `Critical:` chặn Golive của Phase G0:**

- `A01 Broken Access Control`: Khóa triệt để chuỗi tấn công leo thang `ADMIN`. Đóng tự đăng ký công khai (`/api/auth/register`), dựng chốt chặn Gateway `src/proxy.ts` (Next.js 16) kết hợp Higher-order Guard `withApiAuth()` ở tầng Route Handler; bảo vệ `/api/attachments/[id]`, ẩn `internalNotes`/bình luận nội bộ và chặn mạo danh `isStaff` trên `/api/tickets/[ticketId]/**`.
- `A02 Cryptographic Failures`: Mã hóa `AES-256-GCM` toàn bộ 8 trường secrets của `SystemSetting`; che giấu `******` ở `GET /api/system/config`; xóa bỏ `console.log(body)`; gỡ bỏ `cookies.txt` khỏi kho Git và thêm vào `.gitignore`.
- `A03 Stored XSS`: Tích hợp `isomorphic-dompurify` làm Seam trung tâm duy nhất (`src/lib/sanitize.ts`) cho `RichMarkdown` và `WysiwygEditor`; escape HTML trong toàn bộ 5 template Email.
- `A05 Security Misconfiguration`: Cưỡng chế `httpOnly: true` cho cookie phiên `flowboard_session`; bổ sung Security Headers (`X-Content-Type-Options: nosniff`, `CSP: sandbox`, `X-Frame-Options: DENY`) cho `/uploads/*`.
- `A07 Authentication Failures`: Dựng In-memory Rate-limiter (sliding window per-IP) trên `/login`, `/tickets/public`, `/upload`; chuyển `scryptSync` sang `scrypt` async không khóa

Event Loop; thu hồi toàn bộ session/JWT cũ qua `tokenVersion`; cưỡng chế chặn `mustChangePassword` ở tầng API.

2. **Khắc phục lỗi gãy chức năng & Cứng hóa độ tin cậy (`G0-6`):**

- Vá lỗi 404 và format `{ task }` trên `/desktop`; bổ sung alias router `src/app/api/tasks/[taskId]/route.ts`.
- Bọc sinh mã `Task.number` trong `prisma.$transaction` có cơ chế retry tối đa 3 lần với exponential/jitter backoff khi gặp mã lỗi `P2002`.
- Xây dựng endpoint kiểm tra sức khỏe hệ thống `GET /api/health` (xác thực PostgreSQL 17 `SELECT 1`).

3. **Phát hiện & Sửa lỗi trực tiếp trong đợt Review của Tech Lead:**

- **Phát hiện:** Trong `src/app/api/auth/login/route.ts:118` và `src/app/api/auth/change-password/route.ts:50`, lệnh `res.cookies.set("flowboard_session", ...)` vẫn còn sót `httpOnly: false`, vô tình ghi đè cấu hình an toàn của `auth.ts`.
- **Xử lý:** Tech Lead đã lập tức sửa dứt điểm thành `httpOnly: true` (kèm `HttpOnly` trong Set-Cookie header cho form fallback), xác nhận 0 dòng `httpOnly: false` tồn tại trong toàn bộ codebase.

4. **Kết luận: CHẤP THUẬN KỸ THUẬT (TECHNICAL SIGN-OFF) GATE 1** — Đủ điều kiện chuyển giao sang Bước 2.2 (`UX/UI Reviewer`) và Bước 3.1 (`QA Engineer`).

---

2. Trục 1 — Standards Review (Fowler 12 Smells & KZTEK Standards)

2.1. Đánh giá Fowler 12 Smells Checklist

#	Code Smell	Dấu hiệu nhận diện	Đánh giá trên Diff Phase 1	Severity	Kết luận
---	---	---	---	---	---
1	**Long Method**	Method > 20 dòng	Các route handlers đã được module hóa; logic phức tạp (mã hóa, lọc XSS, rate-limit, auth) được tách vào helpers (`crypto-secrets.ts`, `sanitize.ts`, `rate-limit.ts`, `api-guard.ts`).	P3	**PASS**
2	**Large Class**	Class/File > 200 dòng hoặc > 15 methods	Các module mới đều gọn gàng: `api-guard.ts` (92 dòng), `proxy.ts` (75 dòng), `crypto-secrets.ts` (105 dòng), `sanitize.ts` (75 dòng), `rate-limit.ts` (145 dòng), `health/route.ts` (47 dòng). Không phát sinh file backend phình to.	P2	**PASS**
3	**Long Parameter List**	> 4 params trong 1 method	`withApiAuth(handler, options)` gom options thành object `ApiAuthOptions`. `encryptSecret`, `decryptSecret`, `checkRateLimit` đều dùng parameter object hoặc single argument.	P3	**PASS**
4	**Divergent Change**	1 class thay đổi vì nhiều lý do	Tách bạch rõ: `sanitize.ts` chỉ phụ trách làm sạch HTML, `crypto-`	P1	**PASS**

		(vi phạm SRP)	`secrets.ts` chỉ mã hóa dữ liệu, `rate-limit.ts` chỉ đo tần suất request, `api-guard.ts` chỉ kiểm soát phiên và quyền truy cập.		
5	**Shotgun Surgery**	1 thay đổi logic buộc sửa nhiều nơi	Giải quyết dứt điểm: Tạo `withApiAuth()` và `src/proxy.ts` làm Leverage Point tập trung, loại bỏ hoàn toàn việc viết code kiểm tra quyền lặp lại tản mác.	P1	**PASS**
6	**Feature Envy**	Method dùng dữ liệu class khác nhiều hơn chính nó	Không phát hiện vi phạm. Các domain helper nhận đúng input và trả về kết quả tương ứng.	P2	**PASS**
7	**Data Clumps**	Cùng nhóm variables xuất hiện nhiều nơi không đóng gói	Cấu hình RateLimit, Cookie Options, SessionUser, Masked Config đều được định nghĩa thành interface/type TypeScript chặt chẽ.	P2	**PASS**
8	**Primitive Obsession**	Dùng primitive string/int thay cho domain types	Các role (`ADMIN`, `MEMBER`), permission, secret format (`enc:v1:...`), file type (`image`, `video`, `document`) đều có enum/type union rõ ràng.	P3	**PASS**
9	**Switch Statements**	Chuỗi if-else/switch dài thay vì polymorphism	Kiểm tra magic bytes và extension được tổ chức qua Set tra cứu $O(1)$ (`FORBIDDEN_EXTENSIONS.has()`) và helper hàm chuyên biệt.	P2	**PASS**
10	**Parallel Inheritance**	Thêm subclass ở đây buộc thêm ở nơi khác	Không áp dụng (kiến trúc TypeScript Functional & Modular).	N/A	**PASS**
11	**Lazy Class**	Module làm quá ít việc cần inline	Không có module thừa. Mỗi module (`sanitize`, `rate-limit`, `crypto-secrets`) đều có trách nhiệm rõ ràng và tái sử dụng ở nhiều routes.	P3	**PASS**
12	**Speculative Generality**	Viết code dự phòng không ai dùng	Toàn bộ 6 module và các endpoint mới đều phục vụ trực tiếp 10 tiêu chí nghiệm thu Gate 1 theo `ADR-001`.	P3	**PASS**

2.2. Kiểm tra Nguyên lý SOLID & Tiêu chuẩn KZTEK Repo

- **Single Responsibility Principle (SRP):** Đạt. Tách biệt hoàn toàn giữa bảo vệ Gateway (`src/proxy.ts`), xác thực Route (`api-guard.ts`), mã hóa bí mật (`crypto-secrets.ts`), lọc mã độc (`sanitize.ts`) và giới hạn lưu lượng (`rate-limit.ts`).
- **Open/Closed Principle (OCP):** Đạt. `withApiAuth()` dễ dàng mở rộng thêm options kiểm tra permission mới mà không cần sửa logic cốt lõi.
- **Liskov Substitution & Interface Segregation:** Đạt. `AuthenticatedApiHandler` tương thích hoàn hảo với chuẩn Next.js App Router context.
- **Dependency Inversion Principle (DIP):** Đạt. Các route handlers phụ thuộc vào abstraction `getSessionUser` và `withApiAuth` thay vì đọc trực tiếp request headers thủ công.
- **Xử lý Lỗi & Tài nguyên (Resource Cleanup):**
  - Rate-limiter có hàm `cleanupExpiredRecords` chạy định kỳ, chống memory leak khi chạy lâu dài.

- Xóa bỏ `console.log(body)` chứa mật khẩu, thay bằng log lỗi tối giản không chứa PII/Secrets.
- Các transaction DB đều có khối `try/catch` bắt mã lỗi `P2002` chuẩn Prisma.

- **KZTEK Standards Checklist:**
  - [x] Không còn hardcoded secrets trong code.
  - [x] Tuân thủ Next.js 16 file convention (`src/proxy.ts` thay vì `middleware.ts`).
  - [x] Đã cập nhật bản đồ kiến trúc `code-graph/CODE-GRAPH.md` (Version 2.3).
  - [x] Đã xuất bản `.docx` và `.pdf` theo đúng Rule R1/R3.

---

3. Trục 2 — Spec Review (Đối Chiếu Toàn Diện ADR-001 Phase G0)

Mã AC / Yêu cầu kỹ thuật	Nội dung yêu cầu từ ADR-001	Trạng thái	Bằng chứng kiểm tra thực tế (`file:line`)		
---	---	---	---		
AC-G0-1a	Khóa lỗ hổng leo thang Admin trên `/api/users` và `/api/users/[userId]`	**PASS**	`src/app/api/users/route.ts:22,68` và `src/app/api/users/[userId]/route.ts:23,130` bọc trong `withApiAuth(..., { requiredRole: "ADMIN" })`.		
AC-G0-1b	Đóng tự đăng ký công khai (`/api/auth/register` & UI)	**PASS**	`src/app/api/auth/register/route.ts:7-14` trả về HTTP 403 Forbidden; `src/app/login/page.tsx:75-82` gỡ link; `src/app/register/page.tsx:28-85` khóa form tự do.		
AC-G0-1c	Dựng Gateway Proxy tập trung theo chuẩn Next.js 16	**PASS**	`src/proxy.ts:14-75` matcher bảo vệ `/admin/**`, `/api/admin/**`, `/api/users/**`, `/api/notifications/email-logs/**`.		
AC-G0-1d	Bảo vệ tệp đính kèm `/api/attachments/[id]`	**PASS**	`src/app/api/attachments/[id]/route.ts:10-52` kiểm tra auth và quyền xóa (Admin / Uploader / Project Manager).		
AC-G0-1e	Ẩn dữ liệu ticket nội bộ & Chặn giả mạo `isStaff`	**PASS**	`src/app/api/tickets/[ticketId]/route.ts:25-31` xóa `internalNotes` & comments nội bộ; `src/app/api/tickets/[ticketId]/comments/route.ts:39-44` ép `isStaff=false` với user ẩn danh.		
AC-G0-1f	Bảo vệ nhật ký email hệ thống `/email-logs`	**PASS**	`src/app/api/notifications/email-logs/route.ts:9,52,83` yêu cầu `requiredRole: "ADMIN"`.		
AC-G0-2a	Seam làm sạch HTML chống Stored XSS bằng	**PASS**	`src/lib/sanitize.ts:66-75` cấu hình `DOMPurify.sanitize`; tích hợp vào `src/components/ui/rich-`		

	DOMPurify		markdown.tsx:295 và src/components/ui/wysiwyg-editor.tsx:370,410,439.		
AC-G0-2b	Escape HTML trong email thông báo & Kích hoạt TLS SMTP an toàn	PASS	src/lib/mail.ts:46-55 helper escapeHtml áp dụng cho 5 email templates; src/lib/mail.ts:199,284 cấu hình rejectUnauthorized: process.env.SMTP_REJECT_UNAUTHORIZED !== "false".		
AC-G0-2c	Cookie phiên flowboard_session bật httpOnly: true (HTTP LAN & HTTPS)	PASS	src/lib/auth.ts:99,116, src/app/api/auth/login/route.ts:99,118 và src/app/api/auth/change-password/route.ts:50 đều đặt httpOnly: true, secure: process.env.COOKIE_SECURE === "true".		
AC-G0-3a	Mã hóa AES-256-GCM 8 trường secrets trong SystemSetting	PASS	src/lib/crypto-secrets.ts:52-105 sinh chuẩn enc:v1:<iv>:<tag>:<ciphertext>; src/lib/system-config.ts:600-668 mã hóa trước khi lưu DB/file.		
AC-G0-3b	Che giấu secrets ở GET /api/system/config	PASS	src/app/api/system/config/route.ts:21 gọi getMaskedSystemConfigAsync() trả về ******.		
AC-G0-3c	Xóa rò rỉ secrets trong log và gỡ cookies.txt khỏi Git	PASS	src/app/api/system/config/route.ts:139 xóa console.log(body); .gitignore:46 thêm cookies.txt; file cookies.txt đã bị xóa.		
AC-G0-4a	In-memory Rate-limiter cho Login, Public Ticket và Upload	PASS	src/lib/rate-limit.ts:61-100; tích hợp tại login/route.ts:22 (10/min), tickets/public/route.ts:23 (5/min), upload/route.ts:126 (20/min).		
AC-G0-4b	Chặn upload web shell & kiểm tra magic bytes	PASS	src/app/api/upload/route.ts:15-38,64-120,162 chặn 21 extension nguy hiểm, kiểm tra magic bytes PNG/JPEG/GIF/WEBP; next.config.ts:34-40 gắn CSP headers.		
AC-G0-4c	Bắt buộc oaSecretKey cho Zalo Webhook	PASS	src/app/api/integrations/zalo/webhook/route.ts:40-47 từ chối 403 nếu chưa cấu hình secret; xác thực chữ ký SHA256 / MAC.		
AC-G0-5a	Chuyển scrypt sang bất đồng bộ không khóa Event Loop	PASS	src/lib/auth.ts:7,16-33 dùng promisify(scrypt) async trong hashPassword và verifyPassword.		
AC-G0-5b	Thu hồi phiên làm việc qua User.tokenVersion	PASS	prisma/schema.prisma:29 thêm tokenVersion Int @default(1); src/lib/auth.ts:196-200 hủy token nếu version không khớp; tăng version khi đổi mật khẩu (change-password/route.ts:40).		
AC-G0-5c	Chặn tài khoản mustChangePassword ở tầng API	PASS	src/lib/api-guard.ts:47-55 chặn HTTP 403 PASSWORD_CHANGE_REQUIRED ở mọi API trừ luồng đổi mật khẩu.		

AC-G0-6a	Vá lỗi 404 và xử lý dữ liệu `{ task }` trên `/desktop`	**PASS**	`src/app/desktop/page.tsx:129,160` sửa URL PATCH và trích xuất `resData.task`		resData; src/app/api/tasks/[taskId]/route.ts:34-190` tạo router alias đầy đủ GET/PATCH/DELETE.
AC-G0-6b	Đảm bảo tính nguyên tử (Atomic) khi sinh `Task.number`	**PASS**	`src/app/api/projects/[projectId]/tasks/route.ts:128-199` bọc trong `prisma.$transaction` có vòng lặp retry 3 lần xử lý lỗi `P2002`.		
AC-G0-6c	Endpoint kiểm tra sức khỏe hệ thống `/api/health`	**PASS**	`src/app/api/health/route.ts:9-46` thực hiện `SELECT 1` kiểm tra PostgreSQL 17, trả về status 200 OK kèm uptime.		

Tổng kết Spec Review: 21/21 tiêu chí ĐẠT (PASS 100%).

---

4. Tái Kiểm Định An Ninh Chuyên Sâu (OWASP Top 10 + STRIDE Gate 1)

4.1. Bảng Tái Kiểm Định OWASP Top 10 (2021)

Hạng mục OWASP	Kết quả Đợt 1 (ARCH-AUDIT)	Kết quả Đợt 2 (Gate 1 Audit)	Biện pháp kỹ thuật đã triển khai & Dẫn chứng xác thực
---	---	---	---
A01: Broken Access Control	**FAIL (Critical)**	**PASS**	Khóa triệt để quyền `ADMIN` trên `/api/users`, `/api/users/[userId]`, `/api/notifications/email-logs`; đóng `/api/auth/register`; bảo vệ `/api/attachments/[id]`; ẩn `internalNotes` và chặn giả mạo `isStaff` trên `/api/tickets/[ticketId]`. Dựng 2 lớp phòng vệ: Gateway `src/proxy.ts` + Guard `withApiAuth()`.
A02: Cryptographic Failures	**FAIL (Critical)**	**PASS**	Toàn bộ 8 khóa nhạy cảm trong `SystemSetting` được mã hóa AES-256-GCM (`src/lib/crypto-secrets.ts`); `GET /api/system/config` chỉ trả `******`; bật `rejectUnauthorized: true` cho SMTP TLS; xóa sạch `cookies.txt` khỏi Git.
A03: Injection (XSS & Upload)	**FAIL (Critical)**	**PASS**	Triệt tiêu Stored XSS bằng `isomorphic-dompurify` trong `RichMarkdown` và `WysiwygEditor`; escape HTML trong email; chặn 21 đuôi file nguy hiểm (`.html`, `.svg`, `.js`...) và kiểm tra magic bytes trong `/api/upload`. Truy vấn SQL vẫn đảm bảo an toàn tuyệt đối qua Prisma ORM parameterized queries.
A04: Insecure Design	**FAIL**	**PASS (Gate 1)**	Bổ sung Rate-limiting cho các cổng công khai (`/api/tickets/public`, `/api/upload`, `/api/auth/login`); giới hạn dung lượng tải tệp (25MB ảnh/tài liệu, 100MB video); bắt buộc người dùng đăng nhập trước khi tải tệp lên.
A05: Security Misconfiguration	**FAIL (Critical)**	**PASS**	Chuyển cookie `flowboard_session` sang `httpOnly: true` ở 100% các điểm thiết lập (đã sửa lỗi sót `httpOnly: false` trong `login` và

			change-password); bổ sung Security Headers nosniff, CSP: sandbox, X-Frame-Options cho thư mục /uploads/* trong next.config.ts.
A06: Vulnerable Components	**PASS**	**PASS**	Sử dụng Next.js 16.3.1, React 19.2.8, Prisma 7.9.1, isomorphic-dompurify 2.36.0, jose 6.2.9. Đã cập nhật package-lock.json sạch sẽ, không có cảnh báo bảo mật nguy hiểm.
A07: Auth Failures	**FAIL (Critical)**	**PASS**	Cài đặt Rate-limit 10 req/phút chống brute-force trên /api/auth/login; chuyển sang crypto.scrypt async giải phóng Event Loop; cơ chế User.tokenVersion thu hồi ngay lập tức JWT cũ khi đổi mật khẩu; chặn cưỡng chế tài khoản mustChangePassword.
A08: Software & Data Integrity	**FAIL**	**PASS**	Zalo Webhook bắt buộc kiểm tra oaSecretKey và xác thực chữ ký số HMAC-SHA256 trước khi tiếp nhận sự kiện; sinh mã Task.number đồng thời được bảo vệ bằng transaction nguyên tử chống xung đột dữ liệu.
A09: Security Logging & Monitoring	**FAIL**	**PASS (Gate 1)**	Xóa bỏ lệnh console.log(body) chứa mật khẩu trong system/config; bổ sung endpoint giám sát sức khỏe hệ thống /api/health phục vụ Docker và Load Balancer.
A10: Server-Side Request Forgery (SSRF)	**PASS (Cảnh báo)**	**PASS**	Kiểm tra whitelist chặt chẽ cho discordWebhookUrl trong Zod schema validation: chỉ chấp nhận URL hợp lệ bắt đầu bằng https://discord.com/api/webhooks/ hoặc https://discordapp.com/api/webhooks/.

4.2. Phân Tích STRIDE Threat Modeling trên 4 Ranh Giới Tin Cậy (Trust Boundaries)

```
[Public Internet / Portal]  ---(RateLimit + No XSS + No WebShell)--->  [Boundary 1: Public Gateway]
[LAN Web / Workstation]     ---(httpOnly Cookie + withApiAuth + RBAC)-> [Boundary 2: Internal Core App]
[External Webhooks]         ---(HMAC SHA256 Signature Verify)--------> [Boundary 3: Integration Ingress]
[Database & Storage]        ---(AES-256-GCM + UUID Filename)----------> [Boundary 4: Persistence Layer]
```

1. **S — Spoofing (Giả mạo danh tính):**

- *Trước:* Khách hàng có thể gửi "isStaff": true trên bình luận ticket; JWT bị đánh cắp qua XSS do cookie httpOnly: false.
- *Hiện tại:* isStaff và isInternalOnly được xác thực cưỡng chế dựa trên session người gửi thực tế ở server; cookie httpOnly: true ngăn chặn mọi mã script đọc trộm token phiên.

2. **T — Tampering (Sửa đổi trái phép):**

- *Trước:* Người lạ gọi DELETE /api/attachments/[id] xóa file dự án; user thường gọi PATCH /api/users/[id] tự nâng quyền Admin.

- *Hiện tại:* `src/proxy.ts` và `withApiAuth()` khóa chặt quyền `ADMIN`; API attachment kiểm tra quyền sở hữu uploader hoặc project manager.

3. **R — Repudiation (Chối bỏ hành vi):**

- *Hiện tại:* Mọi tác vụ tạo task, đổi trạng thái đều ghi vết `actorId` vào `ActivityLog`. (Bảng `SecurityAuditLog` chuyên sâu sẽ hoàn thiện ở Phase G1 theo đúng lộ trình ADR-001).

4. **I — Information Disclosure (Lộ lọt thông tin):**

- *Trước:* `GET /api/system/config` và `console.log` làm lộ secrets rõ; `GET /api/tickets/[ticketId]` làm lộ `internalNotes`.
- *Hiện tại:* Secrets được mã hóa AES-256-GCM dưới DB và trả về `******` qua `getMaskedSystemConfigAsync()`; `internalNotes` bị xóa bỏ hoàn toàn đối với khách hàng ẩn danh.

5. **D — Denial of Service (Từ chối dịch vụ):**

- *Trước:* Spam login làm treo Event Loop do `scryptSync`; upload file video hàng loạt gây cạn kiệt dung lượng đĩa.
- *Hiện tại:* Rate-limiter giới hạn tần suất request per-IP; `scrypt` async chạy trên thread pool của Node.js; API upload bắt buộc đăng nhập và giới hạn dung lượng tệp.

6. **E — Elevation of Privilege (Leo thang đặc quyền):**

- *Trước:* Đăng ký tự do công khai (`/api/auth/register`) rồi gọi `/api/users` chiếm quyền `ADMIN`.
- *Hiện tại:* Đóng hoàn toàn đăng ký tự do (`403 Forbidden`); toàn bộ API quản trị người dùng bắt buộc quyền `ADMIN` ở cả tầng Gateway lẫn Route Handler.

---

5. Tái Đánh Giá 8 Nhóm Lỗ Hổng Từ Báo Cáo Kiểm Toán Ban Đầu

Nhóm lỗ hổng (`ARCH-AUDIT`)	Tình trạng ban đầu	Hiện trạng sau Phase 1 & Review Phase 2	Phân loại
---	---	---	---
1. Leo thang đặc quyền Admin (A01/E)	`Critical:` User thường tự nâng quyền lên `ADMIN`, xóa tài khoản Admin khác, đăng ký tài khoản tự do.	**ĐÃ GIẢI QUYẾT TRIỆT ĐỂ (RESOLVED):** Đóng đăng ký công khai; Gateway `src/proxy.ts` và Guard `withApiAuth()` khóa quyền `ADMIN` cho toàn bộ nhóm `/api/users/**`.	`PASS`
2. Lộ lọt mật khẩu & Secrets (A02/I)	`Critical:` Plaintext secrets trong DB, `GET /api/system/config` trả mật khẩu rõ, `console.log(body)`, `cookies.txt` trong Git.	**ĐÃ GIẢI QUYẾT TRIỆT ĐỂ (RESOLVED):** Mã hóa AES-256-GCM; che giấu `******`; xóa `console.log`; gỡ `cookies.txt` và thêm vào `.gitignore`.	`PASS`
3. Stored XSS trong Rich Text (A03/S)	`Critical:` Regex sơ sài trong `RichMarkdown` và gán thẳng `innerHTML` trong `WysiwygEditor`.	**ĐÃ GIẢI QUYẾT TRIỆT ĐỂ (RESOLVED):** Chuẩn hóa `isomorphic-dompurify` làm Seam trung tâm lọc sạch toàn bộ HTML hiển thị và nhập liệu.	`PASS`

4. Upload Web Shell & Thực thi mã (A03/A05)	`Critical:` Cho phép upload ẩn danh file `.html`, `.svg`, `.js` phục vụ cùng origin.	**ĐÃ GIẢI QUYẾT TRIỆT ĐỂ (RESOLVED):** Bắt buộc auth; cấm 21 extension; kiểm tra magic bytes nhị phân; gắn CSP sandbox headers; lưu tên file UUID.	`PASS`
5. Cookie phiên không an toàn (A05/S)	`Critical:` Cookie `flowboard_session` đặt `httpOnly: false`.	**ĐÃ GIẢI QUYẾT TRIỆT ĐỂ (RESOLVED):** Bật `httpOnly: true` trên toàn hệ thống (đã vá lỗi sót trong route login/change-password).	`PASS`
6. Khóa Event Loop & Thiếu Rate-limit (A07/D)	`Critical:` `scryptSync` làm treo server; không có rate-limit chống brute-force mật khẩu.	**ĐÃ GIẢI QUYẾT TRIỆT ĐỂ (RESOLVED):** Chuyển sang `scrypt` async; áp dụng Rate-limiter 10 req/phút cho login, 5 req/phút cho ticket, 20 req/phút cho upload.	`PASS`
7. Không thu hồi được JWT cũ (A07/A08)	`Critical:` Đổi mật khẩu không hủy được token cũ; cờ `mustChangePassword` không chặn ở API.	**ĐÃ GIẢI QUYẾT TRIỆT ĐỂ (RESOLVED):** Thêm `User.tokenVersion` tự động tăng khi đổi mật khẩu; `withApiAuth()` chặn `mustChangePassword` ở tầng API.	`PASS`
8. Lỗi 404 `/desktop` & Trùng Task.number (G0-6)	`Required:` Gãy chức năng đổi trạng thái task trên `/desktop`; lỗi `P2002` khi tạo task đồng thời.	**ĐÃ GIẢI QUYẾT TRIỆT ĐỂ (RESOLVED):** Sửa đường dẫn API và parse `{ task }` trên Desktop; tạo router alias `/api/tasks/[taskId]`; bọc transaction retry cho `Task.number`.	`PASS`

6. Đối Chiếu 10 Tiêu Chí Nghiệm Thu Gate 1 (LAN Pilot)

Căn cứ theo bản cam kết kiến trúc tại `docs/architecture/ADR-001-system-architecture-roadmap.md`:

#	Tiêu chí nghiệm thu Gate 1 (LAN Pilot)	Đánh giá kỹ thuật của Tech Lead	Trạng thái
---	---	---	---
1	**Khóa Leo thang Đặc quyền (A01):** Tài khoản `MEMBER`/`VIEWER` và ẩn danh nhận `HTTP 401/403` khi gọi `/api/users`, `/api/users/[id]`, `/api/auth/register`, `/api/attachments/[id]`, `/api/notifications/email-logs`.	Đã kiểm chứng tự động qua `scripts/test_step_1_1.ts`: 7/7 kịch bản trả về đúng 401/403.	**ĐẠT (PASS)**

2	**Chặn Lộ dữ liệu Ticket Nội bộ (A01/I):** Ẩn `internalNotes` và comment nội bộ với khách hàng; cưỡng chế `isStaff = false`.	Đã kiểm chứng tự động qua test case 6.1 & 6.2 của `test_step_1_1.ts`.	**ĐẠT (PASS)**
3	**Triệt tiêu Stored XSS & Bảo vệ Phiên (A03/A05):** HTML qua `DOMPurify`; cookie `httpOnly: true`, tương thích kép HTTP LAN (`COOKIE_SECURE=false`) và HTTPS.	Đã kiểm chứng tự động qua `test_step_1_2.ts` (22/22 pass); Tech Lead đã vá dứt điểm 2 điểm sót `httpOnly: false`.	**ĐẠT (PASS)**
4	**Bảo mật Khóa tích hợp (A02/A09):** Secrets trong `SystemSetting` mã hóa AES-256-GCM; `GET /api/system/config` trả `******`; xóa log và `cookies.txt`.	Đã kiểm chứng tự động qua `test_step_1_2.ts`; xác nhận định dạng mã hóa `enc:v1:...` hoạt động chuẩn xác.	**ĐẠT (PASS)**
5	**An toàn Tải tệp & Rate-Limit cơ sở (A04/A07):** Chặn đuôi thực thi web, kiểm tra magic bytes, CSP headers; Rate-limit chống brute-force trên `/api/auth/login`.	Đã kiểm chứng tự động qua `test_step_1_3.ts` (TEST 1 & TEST 3 pass 100%).	**ĐẠT (PASS)**
6	**Không khóa Event Loop & Kiểm soát Vòng đời Token (A07/Perf):** Dùng `scrypt` async; đổi mật khẩu thu hồi JWT qua `tokenVersion`; chặn `mustChangePassword` ở API.	Đã kiểm chứng qua test case 2 & 7 của `test_step_1_1.ts`.	**ĐẠT (PASS)**
7	**Toàn vẹn Nghiệp vụ Web & Desktop:** Trang `/desktop` cập nhật/tạo task thành công 100%; tạo nhiều task đồng thời không lỗi trùng mã `P2002`.	Đã kiểm chứng qua TEST 5 của `test_step_1_3.ts` (5 task tạo đồng thời sinh mã duy nhất).	**ĐẠT (PASS)**
8	**An toàn Hạ tầng & Sao lưu (Infra):** Bind port PostgreSQL `127.0.0.1:5432`; `/api/health` trả về 200 OK; cronjob `pg_dump` và diễn tập restore.	Endpoint `/api/health` đã hoàn thành và kiểm chứng (TEST 2 pass). Phần cứng hóa Docker compose và diễn tập restore do DevOps Lead thực hiện tại Bước 3.2.	**SẴN SÀNG (READY CHO BƯỚC 3.2)**
9	**Đóng băng Client Chưa Đạt Chuẩn:** Chưa phân phối bộ cài `KztekWorkManagement.Mobile` cũ cho người dùng cuối.	Xác nhận đóng băng bộ cài Mobile cũ theo quyết định CTO; sẽ port lên Avalonia 12.1.0 ở Phase G1 (Plan 3).	**ĐẠT (PASS)**
10	**Nghiệm thu Độc lập (Two-Eyes Sign-off):** Có báo cáo PASS của `security-audit-stride` từ Tech Lead, Smoke/Regression Sign-off của QA Lead và xác nhận hạ tầng của DevOps Lead.	Tech Lead ký xác nhận kỹ thuật tại báo cáo này; bàn giao cho UXR và QA Lead hoàn tất chuỗi nghiệm thu.	**CHẤP THUẬN (SIGNED)**

7. Kết Luận & Quyết Định Kỹ Thuật (Technical Sign-off)

1. **Đánh giá tổng thể:** Toàn bộ các mục tiêu kỹ thuật của Phase G0 nhằm gỡ lệnh `🔴 BLOCK GOLIVE` đã được Senior Developer triển khai đầy đủ, chuẩn mực và đã được Tech Lead kiểm chứng độc lập. Các lỗi ngầm phát hiện thêm trong đợt review (`httpOnly: false`) đã được khắc phục ngay lập tức tại chỗ.
2. **Quyết định của Tech Lead: `✅ APPROVE & TECHNICAL SIGN-OFF GATE 1`.**
3. **Kế hoạch bàn giao các bước tiếp theo trong chuỗi WF-HOTFIX:**

- **Bước 2.2 — UX/UI REVIEWER:** Chạy ứng dụng thật trên trình duyệt để đánh giá trực quan 7 tiêu chí C1–C7 đối với giao diện `/login`, `/register`, soạn thảo rich text `WysiwygEditor` / `RichMarkdown`, và không gian làm việc `/desktop`.
- **Bước 3.1 — QA ENGINEER:** Chạy ứng dụng thật, thực thi kiểm thử nghiệm thu an ninh Gate 1 toàn diện (chặn 401/403, khử XSS, cookie httpOnly trên HTTP/HTTPS LAN, rate-limit, transaction task) và kiểm thử hồi quy luồng nghiệp vụ cốt lõi.
- **Bước 3.2 — DEVOPS LEAD:** Cứng hóa cấu hình Docker Compose (bind `127.0.0.1:5432`, cấu hình healthcheck cho container `app`), thiết lập sao lưu định kỳ `pg_dump`, thực hiện diễn tập khôi phục (restore drill) thành công trên thực tế và ban hành Biên bản Sign-off chính thức mở Golive Tier-1 LAN Pilot.

Hà Nội, ngày 02 tháng 11 năm 2026

Tech Lead (L3 — Lead)

(Đã ký xác nhận kỹ thuật)